

Two tier web app

Owner: Prajwal
Reviewer: KAli
Contributors:
Date Generated: Thu Jul 23 2026



OWASP Threat Dragon

Executive Summary

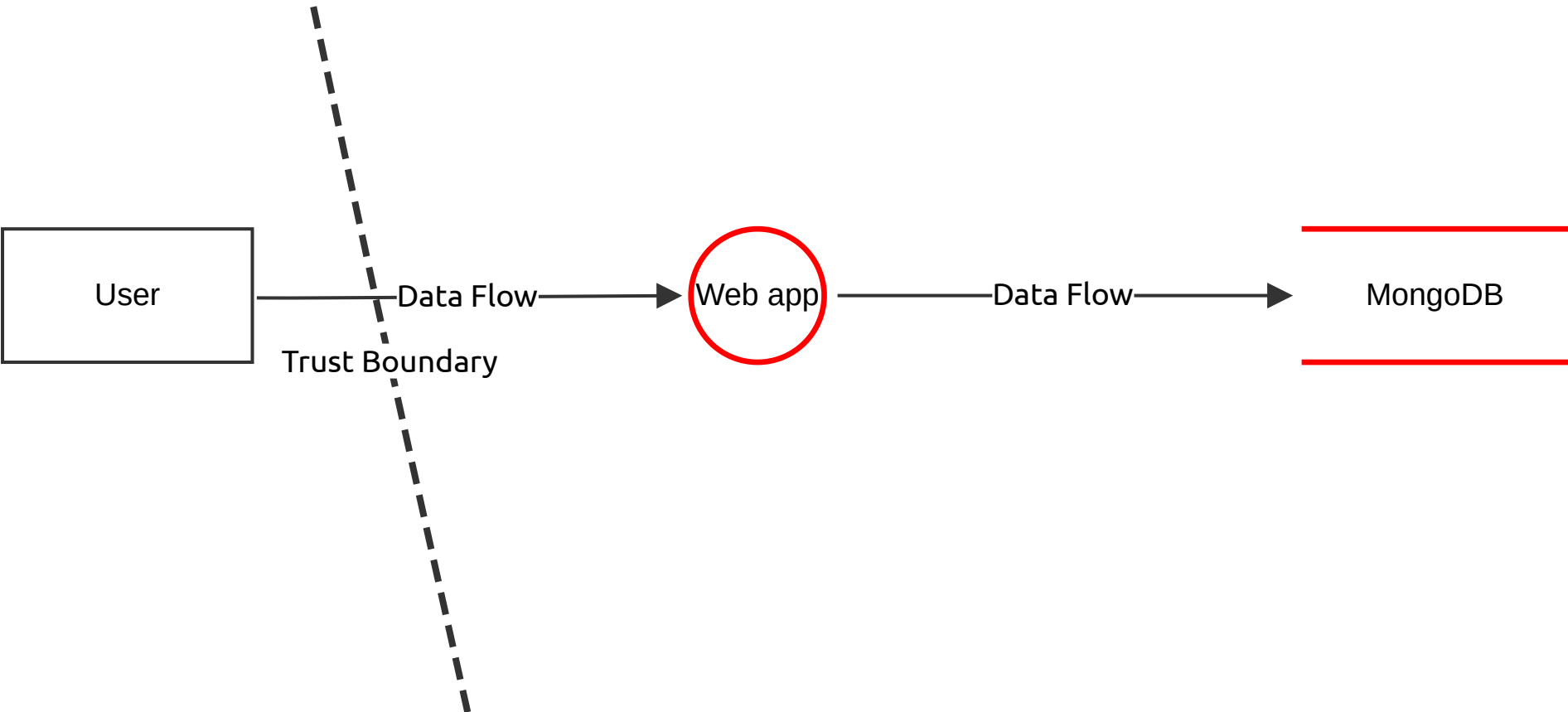
High level system description

Not provided

Summary

Total Threats	13
Total Mitigated	0
Total Open	12
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	12

New STRIDE diagram



New STRIDE diagram

User (Actor)

Properties:							
Number	Title	Type	Severity	Status	Score	Description	Mitigations

Web app (Process)

Properties: Web Application							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
15	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
16	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
17	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation
18			Unknown	Unknown			

MongoDB (Store)

Properties: Stores Credentials, Stores Inventory							
Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
20	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
21	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action
22	Credential cracking	Information disclosure	TBD	Open		See OWASP Automated Threat #7: Brute force, dictionary and guessing attacks used against authentication processes of the application to identify valid account credentials	Defences include restriction of excessive authentication attempts, control of interaction frequency and enforcement of a single unique action

Number	Title	Type	Severity	Status	Score	Description	Mitigations
23	Account creation	Elevation of privilege	TBD	Open		See OWASP Automated Threat #19: Bulk account creation, and sometimes profile population, by using the application’s account signup processes	Defences include control of interaction frequency, enforcement of a single unique a action and enforcement of behavioral workflow
24	Account aggregation	Spoofing	TBD	Open		See OWASP Automated Threat #20: Compilation of credentials and information from multiple application accounts into another system	Defences include control of interaction frequency and prevention of abuse of functionality
25	Coupon cracking	Tampering	TBD	Open		See OWASP Automated Threat #2: Mass enumeration (for example coupon numbers, voucher codes, discount tokens) providing some form of user benefit within the application	Defences include providing anti-automation, guarding against brute force, and preventing abuse of functionality
26	Scalping	Elevation of privilege	TBD	Open		See OWASP Automated Threat #5: Mass acquisition of goods or services using the application in a manner that a normal user would be unable to undertake manually	Defences against this automated threat include control of interaction frequency, enforcement of a single unique a action and enforcement of behavioral workflow

Data Flow (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Data Flow (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------